

פרק 9 – ניהול אבטחת רשת מתקדם

11 שעות עיוני + 3 מעשי · שבועות 27–29

מטרות: עיצוב רשת מאובטחת · ניתוח פגיעות · ניהול סיכונים · הגנה עצמית · Nessus/Nmap
בבגרות: בקורות מנהלי/פיזי/לוגי, Nmap, אתיקה וחוק

לפני שמתחילים – מהניהול הטכני לניהול הארגוני (למי שאין רקע)

עד כה למדנו **סילב** (חומת אש, הצפנה, VPN) פרק זה עוסק ב**לוהי** – ההחלטות והנהלים סביב הכלים: **סיכון** (Risk) – ההסתברות שמשהו רע יקרה, כפול הנזק. אבטחה = ניהול סיכונים, לא ביטולם המוחלט (שבלתי אפשרי). **מדיניות** (Policy) – מסמך שקובע מה מותר ומה אסור בארגון (למשל "אסור להתחבר לרשת הארגון מ-Wi-Fi ציבורי"). **בקרה** (Control) – כל אמצעי שמקטין סיכון. יש שלושה סוגים: **מנהלית** (נהלים), **פיזית** (מנעולים), **לוגית** (סיסמאות, הצפנה). **גיבוי** (Backup) – עותק של המידע שנשמר בנפרד, כדי לשחזר אחרי תקלה/מתקפה. **בדיקת חדירה** (Penetration Test) – לשכור "האקר טוב" שינסה לפרוץ בכוונה, כדי למצוא חולשות לפני שהרעים ימצאו. **הרעיון:** הפרק מחבר את כל הקורס – איך משלבים את כל הכלים לכדי תוכנית אבטחה שלמה לארגון, ומה החוק והאתיקה דורשים.

9.1 מהניתוק הטכני לתמונה הניהולית

שמונת הפרקים הקודמים היו על כלים (ACL, IPS, VPN) ...). פרק 9 הוא על המערכת הניהולית שמחליטה איזה כלי, איפה, וכמה – כי אבטחה מושלמת עולה אינסוף, ואבטחה אפסית עולה בפריצה. זהו איזון של סיכון מול עלות. זה גם הפרק שקושר את הקורס לעולם המקצועי (SOC, CISO), ביקורת, חוק).

9.2 ניהול סיכונים (Risk Management)

הנוסחה

סיכון = איום × פגיעות × ערך הנכס. אם אחד מהם אפס – אין סיכון. אי אפשר לבטל איומים (הם קיימים), אבל אפשר להקטין פגיעות (בקורות) ולהקטין את ההשפעה.

תהליך ניהול הסיכונים

1. **זיהוי נכסים** – מה יש לנו ומה ערכו (מידע, שרתים, מוניטין).
2. **הערכת איומים ופגיעויות** – מה עלול לקרות (סריקות, ראיונות, בדיקות – 9.5).
3. **ניתוח סיכונים** – **כמותי** (בכסף): $ARO \times ALE = SLE$ – ההפסד השנתי הצפוי) או **איכותי** (מטריצה גבוהה/בינוני/נמוך).
4. **טיפול בסיכון** – ראו להלן.
5. **ניטור וחזרה** – סיכון משתנה עם הזמן.

ארבע דרכי טיפול בסיכון (נושא מרכזי)

אסטרטגיה	משמעות	דוגמה
הפחתה / הימנעות (Mitigate/Avoid)	בקורות שמקטינות סיכון, או הפסקת הפעילות המסוכנת	התקנת IPS; הפסקת שירות ישן ופגיע
העברה (Transfer)	מעבירים את הנטל לגורם אחר	ביטוח סייבר; מיקור חוץ לענן
קבלה (Accept)	הסיכון נמוך/עלות הטיפול גבוהה – חיים איתו במודע	לא מצפינים מסך פנימי בעל ערך נמוך
בידוד (Isolation)	מפרידים את המערכת המסוכנת	רשת נפרדת למערכת legacy; DMZ; air-gap

9.3 עקרונות עיצוב רשת מאובטחת

- **הגנה לעומק** (Defense in Depth) – שכבות עצמאיות; כשל באחת לא מפיל הכול.
- **מינימום הרשאות** (Least Privilege) – כל אחד מקבל בדיוק מה שצריך, לא יותר.
- **הפרדת תפקידים** (Separation of Duties) – פעולה קריטית דורשת שני אנשים; מי שמאשר תשלום $\neq$ מי שמבצע. מונע הונאה פנימית.
- **סבב תפקידים** (Job Rotation) – חושף הונאות, מפחית תלות באדם יחיד.
- **Fail-Secure** – במקרה כשל, ברירת המחדל היא לחסום. (deny by default).
- **Zero Trust** – "לעולם אל תסמוך, תמיד תאמת"; אין "פנים מהימן".
- **KISS / פשטות** – מערכת מורכבת קשה לאבטח; מורכבות היא אויב האבטחה.
- **מגוון הגנות** (Diversity) – ספקים שונים בשכבות שונות, כדי שחולשה אחת לא תפיל הכול.

בבגרות (שאלה 6) – שלוש קטגוריות בקרה

מנהלית: כתיבת מדיניות, הנחיות, נהלים, תקנים, איסור עבודה ב-Zoom מרשת לא מאובטחת.
פיזית: הגנה על חדר שרתים וארונות תקשורת.
לוגית: שימוש ברשימות גישה, סיסמאות, מערכות למניעת גישה.

חלוקה משלימה לפי מתי הבקרה פועלת: **מונעת** (Preventive) – מנעול, הצפנה, **מגלה** (Detective) – IDS, מצלמה, לוג, **מתקנת** (Corrective) – גיבוי, (patch, **מרתיעה** (Deterrent) – שלט אזהרה, **משחזרת** (Recov-DRP). – ery

9.4 מדיניות, נהלים ותקנים

מדיניות (Policy)	מסמך-על: מה ולמה. "כל גישה מרחוק דרך VPN"
תקן (Standard)	חובה מדידה: "סיסמה ≥ 12 תווים, MFA"
הנחיה (Guideline)	המלצה גמישה.
נוהל (Procedure)	צעד-אחר-צעד: איך מגדירים VPN.

מסמכים חשובים: **AUP** (Acceptable Use Policy) – מה מותר לעבוד לעשות עם הציוד, מדיניות סיסמאות, מדיניות גיבוי, מדיניות תגובה לאירועים, סיווג מידע (סודי/פנימי/ציבורי).

9.5 בדיקות אבטחה: הערכה, סריקה ובדיקת חדירה

סוג בדיקה	מה זה
Security Audit	בדיקת עמידה במדיניות/תקן (ISO 27001) – מסמכים ותצורות
Vulnerability Assessment	סריקה אוטומטית לזיהוי פגיעויות ידועות (Nessus)
Penetration Test	ניסיון פריצה מבוקר – "לחשוב כמו תוקף" ולהוכיח ניצול
(Security Test & Evaluation) ST&E	בדיקה שיטתית שהבקורות עובדות כמתוכנן (מוזכר בתכנית)

סוגי pentest

Black box (התוקף לא יודע כלום – כמו תוקף חיצוני), **White box** (יודע הכול – יעיל, מהיר), **Gray box** (ידע חלקי – כמו עובד/משתמש). שלבים: תכנון והרשאה → סיור → סריקה → ניצול → דוח.

חובה: אישור בכתב (Scope & Authorization)

בדיקת חדירה ללא אישור כתוב = עבירה פלילית. חייבים: היקף מוגדר (אילו כתובות), חלון זמן, "get out of jail" letter, ואיש קשר. זה גם מה שמלמדים לתלמידים לגבי הכלים בהמשך.

9.6 כלי סריקת פגיעויות (נשאל בבגרות)

כלי	מה עושה
Nmap (Network Mapper)	גילוי, ניתוח ובקרה ברשתות תקשורת: מיפוי מארחים חיים, סריקת פורטים פתוחים, זיהוי שירותים וגרסאות (-sV, זיהוי מערכת הפעלה (-O). זו התשובה בבגרות. Zenmap = ה-GUI.
Nessus	סורק פגיעויות: מריץ אלפי בדיקות מול מארח ומדווח על חולשות ידועות (CVE) עם דירוג חומרה והמלצות תיקון. (התכנית כותבת "NESUS").
SuperScan	סורק פורטים ותיקוני TCP/UDP למערכות Windows (ישן; מוזכר בתכנית).
OpenVAS	חלופה חינמית ל-Nessus
Wireshark	ניתוח תעבורה (packet analyzer)
Metasploit	מסגרת לניצול פגיעויות (בדיקות חדירה)
Kali Linux	הפצת לינוקס עם כל כלי הבדיקה מותקנים

! דוגמאות Nmap (רק ברשת מעבדה מבודדת ובאישור!)
 # אילו מארחים חיים ואילו פורטים nmap 192.168.1.0/24
 # גרסאות שירותים nmap -sV 192.168.1.10
 # ניחוש מערכת הפעלה nmap -O 192.168.1.10
 # SYN scan nmap -sS -p 1-1000 192.168.1.10

סיפור מהחיים: Equifax – פגיעות אחת שלא תוקנה (2017)

דליפת המידע של Equifax חשפה נתונים של 147 מיליון אמריקאים (מספרי ביטוח לאומי, תאריכי לידה). הסיבה: פגיעות ידועה ב-Apache Struts (CVE-2017-5638) עם תיקון זמין חודשיים קודם. סורק פגיעויות היה מוצא אותה תוך דקות – אבל התהליך של Equifax לא סרק את השרת הזה. הלקח: ניהול פגיעויות הוא לא אירוע חד-פעמי אלא תהליך מתמשך (scan → prioritize → patch → verify). זה הלב של פרק 9.

9.7 הגנה עצמית ותגובה לאירועים

"מערכות הגנה עצמית" בתכנית: היכולת של הרשת לזהות ולהגיב אוטומטית. סיסקו קראה לזה Self-SDN (Defending Network) בעבר – שילוב IPS, NAC, קורלציה ותגובה אוטומטית (בידוד מחשב נגוע). היום: SOAR (Security Orchestration, Automation and Response) ו-XDR.

Incident Response – 6 שלבים (SANS/NIST)



הכנה (נהלים, כלים) → זיהוי (SIEM, IDS) → בלימה (ניתוק מהרשת) → מיגור (הסרת הנוזקה) → שחזור (החזרה לפעילות) → הפקת לקחים. הצוות: CSIRT/CERT.

9.8 המשכיות עסקית והתאוששות מאסון

	BCP (Business Continuity Plan)	DRP (Disaster Recovery Plan)
מטרה	שהעסק ימשיך לתפקד בזמן אסון	שחזור מערכות ה-IT אחרי אסון
היקף	כל העסק (אנשים, תהליכים, מבנים)	טכנולוגי (שרתים, נתונים)

BIA (Business Impact Analysis) מזהה תהליכים קריטיים ומגדיר שני יעדים: RTO (Recovery Time Objective) – כמה זמן מותר להיות מושבתים) ו-RPO (Recovery Point Objective) – כמה נתונים מותר לאבד = תדירות הגיבוי). (Worst Case Scenario WCS) – בתכנית) = תכנון לתרחיש הגרוע ביותר.

גיבויים ואתרי גיבוי

- **כלל 1-2-3:** 3 עותקים, 2 מדיות שונות, 1 מחוץ לאתר. (off-site) קריטי נגד כופרה.
- סוגים: מלא (Full), הפרשי (Differential), משלים. (Incremental).
- אתרי גיבוי: Hot site (פעיל, מידי, יקר), Warm site (חלקי), Cold site (מבנה ריק, זול, איטי).
- **בדיקת גיבוי** – גיבוי שלא נבדק שחזור ממנו = לא גיבוי. תרגלו שחזור!

SDLC 9.9 – פיתוח מאובטח

SDLC (Software/System Development Life Cycle) – מחזור חיי פיתוח מערכת. אבטחה חייבת להיכנס **מההתחלה** ("Security by Design", לא כטלאי בסוף – זול ויעיל פי כמה. שלבים: תכנון → ניתוח דרישות → עיצוב → מימוש → בדיקות → הטמעה → תחזוקה (זזה חוזר במעגל). התכנית מציינת "תוכנית מערך" SDLC ו"תחזוקה ותפעול". SDLC.

ב-DevSecOps משלבים בדיקות אבטחה אוטומטיות בכל commit. עקרונות קוד מאובטח: בדיקת קלט (נגד injection ו-buffer overflow – פרק 1, least privilege), ניהול סודות נכון, עדכון ספריות. (Log4Shell).

9.10 אבטחת מערכות מגוונות ושילוב גורמים

- **מייל** – ESA/anti-spam, SPF/DKIM/DMARC (נגד זיוף שולח – פרק 1 phishing).
- **טלפוניה** (VoIP) – SRTP, voice VLAN (פרק 6).
- **אפליקציות** – WAF, OWASP Top 10.
- **אלחוט** – WPA3-Enterprise, WIPS (פרק 6).
- **שילוב גורמים** – לקוחות, שותפים, עובדים: לכל אחד רמת גישה ומדיניות (least privilege), פילוח).
- ניהול מרכזי וחלוקת תפקידים (SOC, NOC), הפרדת תפקידים).

9.11 אתיקה, חוק ואחריות מקצועית

חובה ללמד – זו לא רק "המלצה"

בישראל: **חוק המחשבים, התשנ"ה-1995** אוסר חדירה לחומר מחשב שלא כדין (סעיף 4) – עד 3 שנות מאסר; שיבוש/הפרעה – עד 5 שנים. **חוק הגנת הפרטיות** ותקנות אבטחת מידע (2017) מחייבים ארגונים. באירופה: GDPR (קנסות עד 4% מהמחזור). הבהירו לתלמידים: הרצת Nmap או כלי פריצה על רשת שאינה שלכם וללא אישור בכתב – עבירה פלילית, גם "רק כדי לבדוק".

- **Hacker אתי** (White hat) פועל תמיד עם אישור והיקף מוגדר.
- קודים אתיים מקצועיים: (ISC)², EC-Council.
- Responsible/Coordinated Disclosure – מצאתם פגיעות? מדווחים ליצרן ונותנים זמן לתקן לפני פרסום.
- דילמות: פרטיות מול ניטור עובדים; חשיפת פגיעות מול ניצולה.

9.12 תרגילים לתלמידים

תרגיל 1 – סיווג בקרות

סווגו כל בקרה (מנהלית/פיזית/לוגית) וגם (מונעת/מגלה/מתקנת):
א. מצלמת אבטחה בכניסה. ב. נוהל גיבוי יומי. ג. חומת אש. ד. הדרכת מודעות לעובדים. ה. גיבוי ששוחזר

אחרי כופרה. ו. מנעול ביומטרי לחדר שרתים.

א. פיזית/מגלה ב. מנהלית/מתקנת (מכונה לשחזור) ג. לוגית/מונעת ד. מנהלית/מונעת ה. לוגית או מנהלית/מתקנת (recovery) ו. פיזית/מונעת

תרגיל 2 – טיפול בסיכון

לכל מצב בחרו: הפחתה / העברה / קבלה / בידוד.

א. שרת ישן הכרחי שאי אפשר לעדכן. ב. רכשו ביטוח סייבר. ג. סיכון נמוך של הדפסה בזבזנית – מתעלמים.
ד. מתקנים IPS מול האינטרנט.

א. בידוד (רשת נפרדת) ב. העברה ג. קבלה ד. הפחתה

תרגיל 3 – RTO/RPO

חנות אונליין מגבה כל 6 שעות ולוקח לה 2 שעות לשחזור. אירע כשל ב-13:00, הגיבוי האחרון ב-12:00. א. כמה נתונים אבדו (RPO) בפועל? ב. מתי חוזרים לפעול (RTO)? ג. אם החברה דורשת RPO של שעה – מה משנים?

א. שעה (12:00)–(13:00). ב. 2~15:00 שעות (שחזור). ג. מגבים כל שעה (או רפליקציה רציפה) כדי לצמצם את חלון האובדן.

תרגיל 4 – דיון אתי

תלמיד גילה שאתר בית הספר חושף ציונים דרך שינוי כתובת ב-URL מה עליו לעשות (ומה אסור)? נמקו לפי חוק המחשבים.

מותר/ראוי: לדווח למורה/מנהל הרשת מיד, לתעד בלי לגשת לנתונים של אחרים. אסור: להוריד/לשנות ציונים, לשתף, "לבדוק עד כמה זה גרוע" בגישה נרחבת – זו חדירה לחומר מחשב שלא כדין. Responsible disclosure.

תרגיל 5 – פרויקט מסכם

בחרו ארגון דמיוני (מרפאה / חנות / בית ספר). כתבו מסמך של עמוד: 3 נכסים קריטיים, איום ופגיעות לכל אחד, ובקרה מכל פרק בקורס שתגן עליו. (זה מחבר את כל 9 הפרקים).

דוגמה למרפאה: נכס=תיקים רפואיים → הצפנה (3) AAA+(4) ACL+(7); נכס=זמינות מערכת → IPS (5)+גיבוי/storm control (6)+(9) DRP; נכס=גישה מרחוק של רופאים → (3) MFA+(8) VPN+נתב מוקשח. (2) מודעות עובדים נגד. (1) phishing

9.13 שאלות בסגנון בגרות

שאלה 1

התאימו אמצעי אבטחה (מנהלי/פיזי/לוגי) לתיאור: (1) הגנה על חדר שרתים; (2) כתיבת מדיניות ונהלים; (3) שימוש ברשימות גישה וסיסמאות.

(1) פיזי (2) מנהלי (3) לוגי

שאלה 2

מה מאפשרת תוכנת Nmap? 1. זיהוי וירוסים. 2. זיהוי סוסים טרויאנים. 3. גילוי, ניתוח ובקרה ברשתות תקשורת. 4. חסימת פורטים

3 – גילוי מארחים, סריקת פורטים וזיהוי שירותים. אינה אנטי-וירוס ואינה חוסמת.

שאלה 3

מהן ארבע הדרכים לטיפול בסיכון? תנו דוגמה לכל אחת.
הפחתה (IPS), העברה (ביטוח), קבלה (חיים עם סיכון נמוך), בידוד/הימנעות (רשת נפרדת/הפסקת שירות).

שאלה 4

מה ההבדל בין BCP ל-DRP?

BCP – המשכיות תפקוד כלל העסק בזמן אסון (אנשים, תהליכים).
DRP – שחזור מערכות ה-IT והנתונים.

שאלה 5

עובד הריץ Nmap על רשת חברה מתחרה "כדי לבדוק". האם זו עבירה? נמקו.

כן – סריקה של רשת שאינה שלו וללא אישור מהווה ניסיון חדירה/גישה לפי חוק המחשבים התשנ"ה-1995.
גם "רק בדיקה" אסורה ללא היקף ואישור בכתב.

שאלה 6

מדוע עדיף לשלב אבטחה כבר בשלב העיצוב של SDLC ולא בסוף?

תיקון פגיעות בשלב מוקדם זול ויעיל בהרבה; "Security by Design" מונע פגמים מבניים שקשה וריקם לתקן במערכת גמורה.

9.14 (מעבדה 3) שעות

1. Nmap במעבדה מבודדת בלבד (רשת סגורה, לא רשת בית הספר, באישור): מפו מארחים, סרקו פורטים, זהו שירותים וגרסאות. דונו בכל פלט: מה תוקף לומד ומה מגן לומד.
2. סרקו VM עם שירות ישן; זהו פורט/גרסה פגיעים; הציעו טיפול (patch/כיבוי/ACL) – מדגים את מעגל ניהול הפגיעויות.
3. תכנון (על נייר): קבלו טופולוגיה של ארגון וסמנו את כל הבקורות מ-9 הפרקים במקומן (נתב מוקשח, AAA, IPS, ACL/ZPF, מתג מאובטח, VPN, גיבוי).
4. סימולציית אירוע: "מחשב עובד נדבק בכופרה" – עברו בכיתה את 6 שלבי ה-Incident Response.
5. פרויקט מסכם (תרגיל 5) כמצגת קבוצתית – חזרה מצוינת לבגרות.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ניהול האבטחה, עם תשובות מוכנות.

ש: "אם יש לנו את כל הכלים (חומת אש, IPS, VPN), למה בכלל צריך 'ניהול'?"

ת: כי כלים בלי מדיניות ותהליך לא מספיקים. מי מחליט מה לחסום? מי בודק שהגיבוי עובד? מה עושים כשקורה אירוע? אבטחה היא תהליך ניהולי מתמשך, לא מוצר שקונים פעם אחת.

ש: "אפשר להגיע לאבטחה מושלמת (100%)?"

ת: לא, וזו לא המטרה. אבטחה מושלמת עולה אינסוף ומשתקת עבודה. המטרה היא מינוכיס לווהינ: להשקיע היכן שהסיכון (הסתברות x נזק) הכי גבוה, ולקבל סיכונים קטנים במודע.

ש: "מה ההבדל בין בקרה מנהלית, פיזית ולוגית?"

ת: מנהלית = מדיניות, נהלים, הדרכות (מה שאנשים עושים). פיזית = מנעולים, מצלמות, חדר שרתים נעול (הגנה על החומרה). לוגית/טכנית = סיסמאות, הצפנה, חומת אש, ACL (הגנה בתוכנה). שאלה נפוצה בבגרות.

ש: "מה מאפשרת תוכנת Nmap? האם היא כלי תקיפה או הגנה?"

ת: Nmap מגלה מארחים חיים, סורק פורטים פתוחים ומזהה שירותים/גרסאות. היא תישומיש-וד: תוקף משתמש בה לסיור (פרק 1), ומגן משתמש בה כדי לגלות מה חשוף ברשת שלו לפני שהתוקף יעשה זאת. היא אינה אנטי-וירוס ואינה חוסמת פורטים.

ש: "מה ההבדל בין סריקת פגיעויות (Nessus) לבדיקת חדירה (pentest)?"

ת: סורק פגיעויות (Nessus) הוא כלי יטמוטא שמדווח על חולשות ידועות. בדיקת חדירה היא פדא שמנסה בפועל לנצל אותן ולפרוץ, "לחשוב כמו תוקף", ולהוכיח את הנזק. הסריקה מוצאת דלתות; ה-pentest בודק אילו באמת נפתחות.

ש: "מה ההבדל בין BCP ל-DRP?"

ת: BCP (המשכיות עסקית) = איך העסק דקפתל רישממ בזמן אסון (אנשים, תהליכים, מבנים). DRP (התאוששות מאסון) = איך ה-IT תוכרעמ תא סירזחשמ והנתונים. DRP הוא חלק טכני בתוך ה-BCP הרחב.

ש: "מהו כלל 3-2-1 לגיבויים?"

ת: 3 עותקים של המידע, על 2 סוגי מדיה שונים, כשלפחות 1 נמצא רתאל פוחמ (off-site/ענן). זה קריטי נגד כופרה: אם המתקפה הצפינה את הרשת, יש עותק מנותק לשחזר ממנו. זכרו - יוביג וניא ונממ רוזחש קדבנ אלש יוביג.

ש: "תלמיד מצא חולשה באתר בית הספר. מה מותר לו לעשות?"

ת: לדווח מיד למורה/מנהל הרשת, ולתעד בלי לגשת למידע של אחרים. רוסא להוריד/לשנות נתונים, לשתף, או "לבדוק עד כמה זה חמור" בגישה נרחבת - זו חדירה לחומר מחשב שלא כדין (חוק המחשבים, 1995). זה נקרא Responsible Disclosure.

ש: "למה לשלב אבטחה כבר בשלב התכנון (SDLC) ולא בסוף?"

ת: כי תיקון חולשה שהתגלתה בסוף עולה פי כמה, ולפעמים דורש לבנות מחדש. "אבטחה מהעיצוב" (Security by Design) זולה ויעילה בהרבה מטלאי מאוחר.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
ניהול סיכונים	תהליך זיהוי, הערכה וטיפול בסיכונים אבטחה.
סיכון (Risk)	= איום x פגיעות x ערך הנזק.
טיפול בסיכון	הפחתה, העברה (ביטוח), קבלה, או בידוד/הימנעות.
מדיניות (Policy)	מסמך הקובע מה מותר ואסור בארגון (לא איך).
נוהל (Procedure)	הוראות צעד-אחר-צעד ליישום המדיניות.
בקרה מנהלית	מדיניות, נהלים, הדרכות, בדיקות רקע.
בקרה פיזית	מנעולים, מצלמות, חדר שרתים נעול.
בקרה לוגית	סיסמאות, הצפנה, חומת אש, ACL.
הגנה לעומק (Defense in Depth)	שכבות הגנה עצמאיות; כשל באחת אינו מפיל הכול.
מינימום הרשאות	מתן בדיוק ההרשאות הנדרשות, לא יותר.
הפרדת תפקידים	פעולה קריטית דורשת שני אנשים; מונע הונאה.
Zero Trust	'לעולם אל תסמוך, תמיד אמת' - אין אזור פנימי מהימן.
Vulnerability Assessment	סריקה אוטומטית לזיהוי פגיעויות ידועות. (Nessus)
Penetration Test	ניסיון פריצה מבוקר, באישור, כדי לאתר חולשות.
Nmap	כלי לגילוי מארחים, סריקת פורטים וזיהוי שירותים.
Nessus	סורק פגיעויות המדווח על חולשות ידועות. (CVE)
ST&E	בדיקה שיטתית שהבקות עובדות כמתוכנן.
BCP	תוכנית המשכיות עסקית - שהעסק ימשיך לתפקד בזמן אסון.
DRP	תוכנית התאוששות מאסון - שחזור מערכות ה-IT והנתונים.
RTO / RPO	זמן ההשבתה המרבי המותר (RTO) וכמות הנתונים המרבית לאיבוד. (RPO)
כלל 3-2-1	3 עותקי גיבוי, 2 מדיות, 1 מחוץ לאתר.
SDLC	מחזור חיי פיתוח מערכת; משלבים אבטחה כבר בעיצוב.
חוק המחשבים התשנ"ה-1995	החוק האוסר חדירה ושיבוש של חומר מחשב שלא כדין.
